

CAPSTONE BACKEND DELIVERABLE

SmartStock API Documentation

Complete endpoint reference with authentication, expected input, sample JSON, output, and error behavior.

Project	SmartStock Inventory and Sales Management System
Prepared by	Ruhang Liu
Document	Backend API Documentation
Date	July 25, 2026

Implementation status: 19 APIs implemented, integrated with SQLite, and covered by 27 automated integration tests.

1. API Overview

The SmartStock backend is a REST API built with Node.js and Express. It supports authenticated inventory and sales workflows for a small retail business. SQLite provides persistent storage, while bearer-token sessions and role middleware separate administrator and employee permissions.

Base URL	http://localhost:4000
Content type	application/json
Authentication	Authorization: Bearer <token>
Roles	admin; employee
Database	SQLite through the Node.js node:sqlite module

2. Standard Response Conventions

Successful responses use a success flag and a data object or array.

```
{
  "success": true,
  "data": {
    "example": "value"
  }
}
```

Errors use a false success flag and a human-readable message.

```
{
  "success": false,
  "message": "Authentication required"
}
```

3. Endpoint Summary

Method	Endpoint	Access	Purpose
POST	/api/auth/login	Public	Log in
GET	/api/auth/me	Authenticated	Get current user
POST	/api/auth/logout	Authenticated	Log out
POST	/api/auth/register	Admin	Register staff user
GET	/api/products? search=Scarf&category=Accessories	Authenticated	List and search products
GET	/api/products/low-stock	Authenticated	List low-stock products
POST	/api/products	Admin	Create product
PUT	/api/products/1	Admin	Update product
DELETE	/api/products/9	Admin	Delete product
GET	/api/sales	Authenticated	List sales
POST	/api/sales	Admin or Employee	Record sale
GET	/api/sales/report	Authenticated	Get dashboard report
GET	/api/orders	Authenticated	List orders
POST	/api/orders	Admin	Create order
PUT	/api/orders/4	Admin	Update order status
GET	/api/customers	Authenticated	List customers

POST	/api/customers	Admin	Create customer
GET	/api/settings	Authenticated	Get settings
PUT	/api/settings	Admin	Update settings

4. Detailed API Specifications

Authentication

4.1 POST /api/auth/login

Name	Log in
Access	Public
Purpose	Validates user credentials and creates a seven-day authenticated session.
Errors	401 - Incorrect email or password

Sample JSON input

```
{
  "email": "admin@smartstock.com",
  "password": "admin123"
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "token": "<64-character-token>",
    "user": {
      "id": 1,
      "name": "Alicia Chen",
      "email": "admin@smartstock.com",
      "role": "admin"
    }
  }
}
```

4.2 GET /api/auth/me

Name	Get current user
Access	Authenticated
Purpose	Returns the user associated with the active bearer token.
Errors	401 - Session expired or invalid

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 1,
    "name": "Alicia Chen",
    "email": "admin@smartstock.com",
    "role": "admin"
  }
}
```

4.3 POST /api/auth/logout

Name	Log out
Access	Authenticated
Purpose	Deletes the active session token.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "logged_out": true
  }
}
```

4.4 POST /api/auth/register

Name	Register staff user
Access	Admin
Purpose	Creates an admin or employee account. Passwords must contain at least eight characters.
Errors	400 - Invalid fields or duplicate email; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "name": "Jordan Lee",
    "email": "jordan@example.com",
    "password": "password123",
    "role": "employee"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 3,
    "name": "Jordan Lee",
    "email": "jordan@example.com",
    "role": "employee"
  }
}
```

Products

4.5 GET /api/products?search=Scarf&category=Accessories

Name	List and search products
Access	Authenticated
Purpose	Returns the catalog, optionally filtered by free-text search and exact category.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "sku": "DW-SCF-001",
      "name": "Cloud-Dyed Silk Scarf",
      "origin": "Dali, Yunnan",
      "material": "Mulberry Silk",
      "dye_technique": "Bound Resist",
      "category": "Accessories",
      "price": 48,
      "cost": 19,
      "quantity": 12,
      "low_stock_threshold": 5,
      "created_at": "2026-07-25 21:14:51",
      "updated_at": "2026-07-25 21:14:51"
    }
  ]
}
```

4.6 GET /api/products/low-stock

Name	List low-stock products
Access	Authenticated
Purpose	Returns products whose quantity is less than or equal to their low-stock threshold.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "sku": "DW-SCF-001",
      "name": "Cloud-Dyed Silk Scarf",
      "origin": "Dali, Yunnan",
      "material": "Mulberry Silk",
      "dye_technique": "Bound Resist",
      "category": "Accessories",
      "price": 48,
      "cost": 19,
      "quantity": 4,
      "low_stock_threshold": 5,
      "created_at": "2026-07-25 21:14:51",
      "updated_at": "2026-07-25 21:14:51"
    }
  ]
}
```

4.7 POST /api/products

Name	Create product
Access	Admin
Purpose	Adds a validated product to the catalog. SKU values must be unique.
Errors	400 - Validation error or duplicate SKU; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "sku": "DW-SCF-001",
    "name": "Cloud-Dyed Silk Scarf",
    "origin": "Dali, Yunnan",
    "material": "Mulberry Silk",
    "dye_technique": "Bound Resist",
    "category": "Accessories",
    "price": 48,
    "cost": 19,
    "quantity": 12,
    "low_stock_threshold": 5
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 1,
    "sku": "DW-SCF-001",
    "name": "Cloud-Dyed Silk Scarf",
    "origin": "Dali, Yunnan",
    "material": "Mulberry Silk",
    "dye_technique": "Bound Resist",
    "category": "Accessories",
    "price": 48,
    "cost": 19,
    "quantity": 12,
    "low_stock_threshold": 5,
    "created_at": "2026-07-25 21:14:51",
    "updated_at": "2026-07-25 21:14:51"
  }
}
```

4.8 PUT /api/products/1

Name	Update product
Access	Admin
Purpose	Updates all managed fields for an existing product.
Errors	400 - Validation error; 404 - Product not found; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "sku": "DW-SCF-001",
    "name": "Cloud-Dyed Silk Scarf",
    "origin": "Dali, Yunnan",
    "material": "Mulberry Silk",
    "dye_technique": "Bound Resist",
    "category": "Accessories",
    "price": 52,
    "cost": 19,
    "quantity": 20,
    "low_stock_threshold": 5
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 1,
    "sku": "DW-SCF-001",
    "name": "Cloud-Dyed Silk Scarf",
    "origin": "Dali, Yunnan",
    "material": "Mulberry Silk",
    "dye_technique": "Bound Resist",
    "category": "Accessories",
    "price": 52,
    "cost": 19,
    "quantity": 20,
    "low_stock_threshold": 5,
    "created_at": "2026-07-25 21:14:51",
    "updated_at": "2026-07-25 21:14:51"
  }
}
```

4.9 DELETE /api/products/9

Name	Delete product
Access	Admin
Purpose	Deletes a product only when it has no sales history.
Errors	404 - Product not found; 409 - Product has sales history; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 9
  }
}
```


Sales

4.10 GET /api/sales

Name	List sales
Access	Authenticated
Purpose	Returns sales with product, channel, region, quantity, total, and date information.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "product_id": 1,
      "product_name": "Cloud-Dyed Silk Scarf",
      "sku": "DW-SCF-001",
      "quantity_sold": 2,
      "total_price": 96,
      "destination_region": "Canada",
      "sales_channel": "Online Store",
      "sale_date": "2026-07-25 21:30:00"
    }
  ]
}
```

4.11 POST /api/sales

Name	Record sale
Access	Admin or Employee
Purpose	Records a sale, calculates the total from the server-side product price, and atomically reduces inventory.
Errors	400 - Invalid quantity, product not found, or insufficient stock

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "product_id": 1,
    "quantity_sold": 2,
    "destination_region": "Canada",
    "sales_channel": "Online Store"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 1,
    "product_id": 1,
    "product_name": "Cloud-Dyed Silk Scarf",
    "sku": "DW-SCF-001",
    "quantity_sold": 2,
    "total_price": 96,
    "destination_region": "Canada",
    "sales_channel": "Online Store",
    "sale_date": "2026-07-25 21:30:00"
  }
}
```

4.12 GET /api/sales/report

Name	Get dashboard report
Access	Authenticated
Purpose	Returns aggregated revenue, inventory, order, customer, category, region, and best-seller metrics.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "total_revenue": 96,
    "units_sold": 2,
    "sales_count": 1,
    "total_products": 8,
    "total_inventory": 147,
    "inventory_cost": 3475,
    "inventory_retail_value": 8901,
    "low_stock_count": 2,
    "pending_orders": 2,
    "total_customers": 3,
    "best_seller": {
      "name": "Cloud-Dyed Silk Scarf",
      "sku": "DW-SCF-001",
      "units": 2
    },
    "by_category": [
      {
        "category": "Accessories",
        "quantity": 45
      }
    ],
    "by_region": [
      {
        "region": "Canada",
        "revenue": 96,
        "units": 2
      }
    ],
    "monthly": [
      {
        "month": "2026-07",
        "revenue": 96
      }
    ]
  }
}
```

Orders

4.13 GET /api/orders

Name	List orders
Access	Authenticated
Purpose	Returns purchase and international orders ordered by creation date.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "supplier": "Online Store",
      "product_name": "Moonfold Cotton Kimono",
      "quantity": 2,
      "status": "In Transit",
      "destination_region": "United Kingdom",
      "order_type": "International",
      "created_at": "2026-07-25 21:14:51"
    }
  ]
}
```

4.14 POST /api/orders

Name	Create order
Access	Admin
Purpose	Creates a purchase or international order record.
Errors	400 - Missing or invalid fields; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "supplier": "Zhoucheng Indigo Workshop",
    "product_name": "Cloud-Dyed Silk Scarf",
    "quantity": 20,
    "status": "Pending",
    "destination_region": "China",
    "order_type": "Purchase"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 4,
    "supplier": "Zhoucheng Indigo Workshop",
    "product_name": "Cloud-Dyed Silk Scarf",
    "quantity": 20,
    "status": "Pending",
    "destination_region": "China",
    "order_type": "Purchase",
    "created_at": "2026-07-25 21:40:00"
  }
}
```

4.15 PUT /api/orders/4

Name	Update order status
Access	Admin

Purpose	Changes an order to Pending, Processing, In Transit, Delivered, or Cancelled.
Errors	400 - Invalid status; 404 - Order not found; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "status": "In Transit"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 4,
    "supplier": "Zhoucheng Indigo Workshop",
    "product_name": "Cloud-Dyed Silk Scarf",
    "quantity": 20,
    "status": "In Transit",
    "destination_region": "China",
    "order_type": "Purchase",
    "created_at": "2026-07-25 21:40:00"
  }
}
```

Customers

4.16 GET /api/customers

Name	List customers
Access	Authenticated
Purpose	Returns customer contact, region, and purchase-total information.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": [
    {
      "id": 1,
      "name": "Mina Patel",
      "email": "mina@example.com",
      "phone": "+1 312 555 0101",
      "region": "United States",
      "total_purchases": 240.5
    }
  ]
}
```

4.17 POST /api/customers

Name	Create customer
Access	Admin
Purpose	Adds a customer to the cross-border customer directory.
Errors	400 - Name or email missing; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "name": "Amelia Brooks",
    "email": "amelia@example.com",
    "phone": "+44 7700 900123",
    "region": "United Kingdom"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 4,
    "name": "Amelia Brooks",
    "email": "amelia@example.com",
    "phone": "+44 7700 900123",
    "region": "United Kingdom",
    "total_purchases": 0
  }
}
```

Settings

4.18 GET /api/settings

Name	Get settings
Access	Authenticated

Purpose	Returns the single workspace settings record.
Errors	401 - Authentication required

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 1,
    "store_name": "Indigo Trail Studio",
    "store_email": "ops@indigotrail.com",
    "default_threshold": 5,
    "admin_name": "Alicia Chen",
    "currency": "USD"
  }
}
```

4.19 PUT /api/settings

Name	Update settings
Access	Admin
Purpose	Updates store identity, default stock threshold, administrator, and currency.
Errors	400 - Invalid settings; 403 - Insufficient permission

Sample JSON input

```
{
  "headers": {
    "Authorization": "Bearer <token>"
  },
  "body": {
    "store_name": "Indigo Trail Studio",
    "store_email": "ops@indigotrail.com",
    "default_threshold": 6,
    "admin_name": "Alicia Chen",
    "currency": "USD"
  }
}
```

Sample JSON output

```
{
  "success": true,
  "data": {
    "id": 1,
    "store_name": "Indigo Trail Studio",
    "store_email": "ops@indigotrail.com",
    "default_threshold": 6,
    "admin_name": "Alicia Chen",
    "currency": "USD"
  }
}
```

5. Authentication and Authorization Rules

- Public access is limited to POST /api/auth/login.
- All business endpoints require a valid bearer token.
- Employees can view business data and record sales.
- Administrators can manage products, orders, customers, settings, and staff accounts.
- Session tokens expire seven days after login and are invalidated immediately on logout.

6. Transaction and Validation Rules

- Product SKU values are normalized to uppercase and must be unique.
- Price, cost, quantity, and stock thresholds must be non-negative.
- Sale totals are calculated from the database product price, not from client-submitted totals.
- A sale and its inventory reduction are executed in one database transaction.
- A sale is rejected when requested quantity exceeds available stock.
- A product with sales history cannot be deleted, preserving reporting integrity.